

Stack 07 full code audit and remediation — 2026-09-24

Scope and identity

This records an owner-requested full code audit of [PR #837](#) at 9e9ccecac878b3760e971b81fef095870362e291, over its 53-path diff from the Stack 06 base efdeb678bc33c616cf8048fb5773548f0da96fa7, and the remediation of every finding. It was run after the second Copilot review had been dispositioned. It is not a Copilot review and does not count as one.

Five independent read-only reviewers covered streamed EIP-712, the ERC-7730 catalog and program interpreter, the ABI decoders and formatters, the signing-flow integration, and the test/CI/report evidence. The top findings were re-read against the source before remediation began.

Remediation commits on top of 9e9ccecac:

- 2621b80b3 — firmware and native tests.
- 33373fbf9 — CI, tooling, the Stack 07 wire regressions and the python-keepkey pin 1d42a1fa4 → 4f80b087f643df713fb8492b463e6f885d2e90bc (BitHighlander/python-keepkey branch audit/715-stack07-remediation).
- The commit containing this document — corrections to the Stack 07 review and retrospective.

Findings and dispositions

#	Sev	Finding at 9e9ccecac	Disposition and evidence
1	P1	Streamed EIP-712 screens were titled with the bare member name: the primary type was hashed but never shown, domain and message were indistinguishable, array elements were all titled "item", and there was no signer or final approval screen. Deposit and Withdraw with identical members drew identical screens.	Fixed. Every leaf is titled with the domain or the primary type and its body opens with the full path (from.wallet, to[1].wallet). One final "Sign Typed Data" screen names the primary type and the checksummed signing address on every signature; declining returns no signature. Native and device tests.
2	P1	An ERC-7730 string capture with an embedded NUL was accepted (valid UTF-8) and confirm("%s") stopped at it: the device showed a prefix of what the contract receives. The raw review that follows shows only a data hash.	Fixed. <code>erc7730_format_text()</code> refuses NUL, C0 and DEL and escapes the rest. Native tests.
3	P1	The python-keepkey assertion "unlimited approval refused with no ButtonRequest" could not fail: the expected-response exception embeds the expected text, so assertIn passed for any device response.	Fixed in python-keepkey 546dcb0: the request is sent raw and the first response must be exactly <code>Failure_ActionCancelled</code> "Unlimited ERC20 approval is disabled". Shown to fail on a wrong message and a wrong code. The firmware behaviour itself was correct.
4	P2	An unused preloaded ERC-7730 definition survived Initialize, Cancel, ClearSession, autolock and unrelated requests, pulling the next ordinary request onto the certified path.	Fixed. Dispatch discards it for every request other than its own chunks, EthereumSignTx and EthereumSignTypedData; every session boundary discards it. <code>Fsm.Erc7730PreloadEndsAtEverySessionBoundary</code> plus a wire test.

#	Sev	Finding at 9e9ccecac	Disposition and evidence
5	P2	approve () was recognised only with 12 zero bytes after the selector. A dirty spender word, which pre-0.8 Solidity masks, skipped the unlimited-allowance guard and reached generic hash-only signing. Present before this stack.	Fixed. The selector alone selects the allowance policy; a non-canonical spender word is refused before any screen. Fsm.DirtySpenderWordCannotBypassApprovalPolicy plus a wire test.
6	P2	Typed-data permits were outside the unlimited-approval policy, and they sign without AdvancedMode.	Fixed by owner direction ("fix them all"). Unlimited EIP-2612 Permit.value, DAI Permit.allowed = true and Permit2 PermitDetails/TokenPermissions.amount are refused before that leaf's screen. Native tests cover all four; device tests cover EIP-2612 and Permit2.
7	P2	The OLED font draws every non-ASCII byte as one glyph and the pager drops leading spaces, so distinct strings could draw the same screen.	Fixed for EIP-712 and ERC-7730 strings: non-ASCII bytes, backslash and edge or doubled spaces are escaped. The board pager is unchanged.
8	P2	confirm () refuses a body of 352 characters or more, so EIP-712 bytes over about 170 bytes and long strings were refused and reported as a user cancel, and ~3 KB of stack buffers could never be used. Seaport was listed as supported but could never fit 12 slots.	Fixed. Long values are shown in numbered parts, each a required confirmation; a value that cannot be displayed is a validation failure, not a cancel. EIP712_MAX_SLOTS is 24, which fits Seaport orders of up to seven items. Native and device tests.
9	P2	ERC-7730 trust gaps: EIP-712 definitions with a zero header contract ignored their signed deployments; revocation epochs and provider_id were parsed but unenforced; delegate-cert scope bytes were unauthenticated while a test claimed otherwise; the displayed signer fingerprint was 32 bits.	Deployments are enforced: a definition applies only at a signed deployment matching the typed data's chain and verifyingContract. ERC7730_MIN_ISSUANCE_EPOCH gives a firmware-update revocation lever (currently 0); revocation epoch and provider_id are documented as unenforced. The Vault certificate carries data in the unchecked cert bytes, so they are documented rather than zero-checked, and the overclaiming test now asserts only what is signed. Fingerprints are 64 bits.
10	P2	Evidence errors: the pin was only on an unmerged branch with no PR; the review doc misattributed the CoinTable and lint fixes to de7457b5d and described the review of 9e03d46ab as coming after it; Stack 07 counts were stale; the firmware validator required by the compiler conformance tests did not exist, so those tests always skipped; a Stack 07 array test was gated on a later block's capability.	SHAs, counts and the pin statement are corrected in the review and retrospective. The new pin is published and carried by draft python-keepkey PR #113 . tools/erc7730-validate runs programs through the firmware's catalog verifier, and CI requires it on the full product. The array test is gated on what it needs and now checks digests against an independent encoder.

#	Sev	Finding at 9e9ccecac	Disposition and evidence
11	P3	Test and display gaps: no Merkle-proof or most negative-authentication coverage; the streaming ABI decoder lacked the validator's negatives; integers shown as hex; addresses without EIP-55; verifier and replay-reader limits disagreed; runtime labels were used as screen titles; zero literals compared inconsistently; <code>primaryType</code> : "EIP712Domain" signed the wrong digest; an unreachable in-progress check; wire refusals asserted only the Failure type; the CoinTable variant was inferred from the device; the contract JUnit files were not required by the report.	All fixed with tests; see the commit messages. ERC-7730 amounts remain in base units, because 7.15 executes only the raw formatter and has no token records to scale by.

New defect found by the new evidence

Once the firmware validator existed, 56 of the 1,450 official registry calldata formats compiled to programs the device refuses: 46 `tokenAmount` fields with no token (formatter kind 3 needs a token argument), 8 paths iterating two nested arrays (the verifier accepts one [] step per path) and 2 ABIs nested deeper than eight levels. The earlier claim that all 1,450 formats reach firmware had never been checked. The compiler now emits the raw formatter when no token is named, and refuses the other two shapes by name. The registry test requires every format to pass the firmware validator or be one of those 10 named refusals.

Verification

All local runs used the CI base image `kktech/firmware@sha256:7438e539...`

- Native, full: firmware-unit 622, board 19, crypto 18, Zcash crypto 72, all passing. Bitcoin-only: 135, 19, 18.
- Negative controls: the new EIP-712 walk, preload-lifetime and dirty-spender native tests, every new or changed wire assertion, and the compiler conformance suite (run against an always-refusing validator) were each shown to fail with the protection removed. The ERC-7730 native tests use hand-built fixtures and spec vectors, not output of the code under test.
- ARM `MinSizeRel` links and `tools/check_sram_budget.py`: full reserve 18,336 B (was 18,896 B), largest frame 7,664 B, pass; Bitcoin-only 39,136 B (unchanged), pass.
- Stack along the certified-calldata path: `fsm_msgEthereumTxAck` 1,448 + `confirm_erc7730_intent_and_continue` + `continue_ethereum_sign_tx` 256 + `ethereum_signing_init` 416 + `confirm` 304 + drawing. That is about 4 KB including the 513-byte formatted-value buffer, well inside the reserve.
- `cppcheck` 2.13 (Ubuntu 24.04, CI flags): zero findings. `clang-format` 20: clean on every changed file. `actionlint` and shell syntax: clean.
- CI-equivalent `docker compose` integration on the committed head, both variants: results are recorded in the PR description with the hosted run.

Copilot review of the remediated head

The owner authorized one request on `f600da9d9`. [Review 5313258873](#) (Lite) returned **Changes recommended**. It listed all seven second-round findings as resolved and raised three new ones. All three were real:

Comment	Finding	Disposition
4100999029	ERC-7730 intent text and field labels reached the screen raw, although the catalog accepts non-ASCII bytes and edge or doubled spaces in program strings.	Fixed. Intent and labels go through <code>erc7730_format_text()</code> like values and split into numbered screens when long. The official registry uses edge spaces as sentence fragments in 379 of its 6,396 compiled strings, so the verifier does not reject them. The registry has no non-ASCII or doubled spaces, so real descriptors display unchanged. Wire test <code>test_non_ascii_intent_is_escaped_no_t_drawn_as_glyphs</code> compares against a same-length ASCII intent. It fails on <code>f600da9d9</code> , where both drew the same number of screens (4 and 4), and passes after the fix (8 and 4).
4100999081	Bitcoin-only runs required the ERC-7730 registry that only the full product uses.	Fixed. The registry export and check, and the CI fetch and pin check, now run only for the full variant.
4100999118	The report's JUnit reader let a later duplicate testcase overwrite an earlier failing one.	Fixed. Duplicate testcases are refused. A synthetic duplicate is rejected, the real Stack 06/07 files contain none, and the report validator tests pass.

Copilot review of the round-3 fixes

On owner approval, [review 5313747274](#) (Lite) on a74532eb9 marked all three round-3 findings resolved and raised two new ones:

Comment	Finding	Disposition
4101396205	The typed-data response was initialised in the shared <code>msg_resp</code> arena before the final "Sign Typed Data" confirmation. A <code>DebugLink GetState</code> answered during that screen runs <code>RESP_INIT</code> on the same arena.	Real, introduced by this remediation, and limited to <code>DEBUG_LINK</code> builds. The address is now kept in a local, the node is scrubbed before the confirmation and derived again after approval, and the response is built only after signing. The <code>pyk</code> streaming tests now also assert the reported address. Under screenshot capture, which reads state at every button request, <code>a74532eb9</code> returned an empty address and 5 of 5 signing tests failed; the fix passes 5 of 5.
4101396237	<code>python-keepkey-tests.sh</code> was said to run contract JUnit validation before those files exist.	Not a defect. The script calls <code>python-keepkey's</code> report script, which has no contract validation. The firmware <code>scripts/generate-test-report.py</code> that holds <code>validate_contract_junit()</code> runs only in CI's <code>generate-test-report</code> job, after both integration legs upload their JUnit files. Hosted runs 36085522402 and 36096967483 and the local compose run all passed through this sequence.

Open items for the owner

- SRAM: the full product's reserve fell by 560 B. `tools/sram-budgets.json` requires explicit review of any single-commit increase above 256 B; 384 B of it is the Seaport-capable slot pool.
- `increaseAllowance`, `setApprovalForAll` and `Permit2` approve calldata are still outside the allowance policy. That predates this stack and was not an audit finding against it.
- Physical-device verification, including OLED photographs of the new typed-data screens, has not been done.
- Copilot has not reviewed the fix for its fourth-round finding. A further request needs separate owner approval.